

SIMATS ENGINEERING
ASSESSMENT TOOL 2 – APPLICATION-BASED QUESTIONS (High)

Course:	Code:	CO: CO5
Duration:	Total Marks: 100	Reg No / Name :

COURSE OUTCOME COVERED

CO5: *Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Instructions: Answer all questions. Each question carries 20 marks.

Code of conduct:

I __M Kavya 192472370__ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: kavya

1. A mid-sized financial organization operates several legacy Windows servers where multiple RPC services remain exposed due to delayed patching cycles caused by operational constraints. Recently, abnormal traffic patterns and unauthorized connection attempts have been observed within the internal network. As a security analyst, evaluate how attackers could exploit these RPC vulnerabilities to gain unauthorized access and escalate privileges. Assess the level of risk associated with delaying patches in such environments and justify whether immediate patch deployment or controlled maintenance scheduling is more appropriate. Recommend suitable mitigation strategies to reduce exposure without affecting business continuity.
2. A web application used for online transactions suffers from multiple vulnerabilities, including cross-site scripting (XSS), cross-site request forgery (CSRF), and weak session management practices. Users report unauthorized transactions and session hijacking incidents. Evaluate how attackers could combine these vulnerabilities to execute complex attacks affecting user accounts. Assess the risks associated with poor session handling and lack of input validation. Justify the need for a layered security approach and recommend comprehensive mitigation strategies to secure the application.
3. An enterprise uses an outdated IIS server to host multiple internal and external applications, and recent vulnerability scans indicate several unpatched critical flaws. Despite warnings, the organization delays updates due to fear of downtime and service disruption. Assess how attackers could exploit these vulnerabilities to gain unauthorized access or execute remote code. Evaluate the risks associated with delaying security updates in such environments and justify whether immediate patching or temporary isolation is more appropriate. Recommend strategies to ensure both security and service availability.

4. A mobile application used by customers stores sensitive information such as login credentials and personal data in plaintext within the device storage. Additionally, the application communicates with backend servers over unsecured channels. Evaluate how attackers could exploit these weaknesses through device compromise or network interception. Assess the potential impact on user privacy and organizational reputation. Justify the need for encryption and recommend secure storage and communication techniques.
5. A system administrator disables the Windows firewall temporarily to troubleshoot connectivity issues but forgets to re-enable it. Within a short period, multiple unauthorized access attempts are detected. Evaluate how attackers could exploit this temporary exposure to gain access to critical services. Assess the risks associated with mismanagement of security controls and justify the importance of enforcing automated policies. Recommend administrative safeguards to prevent such incidents.

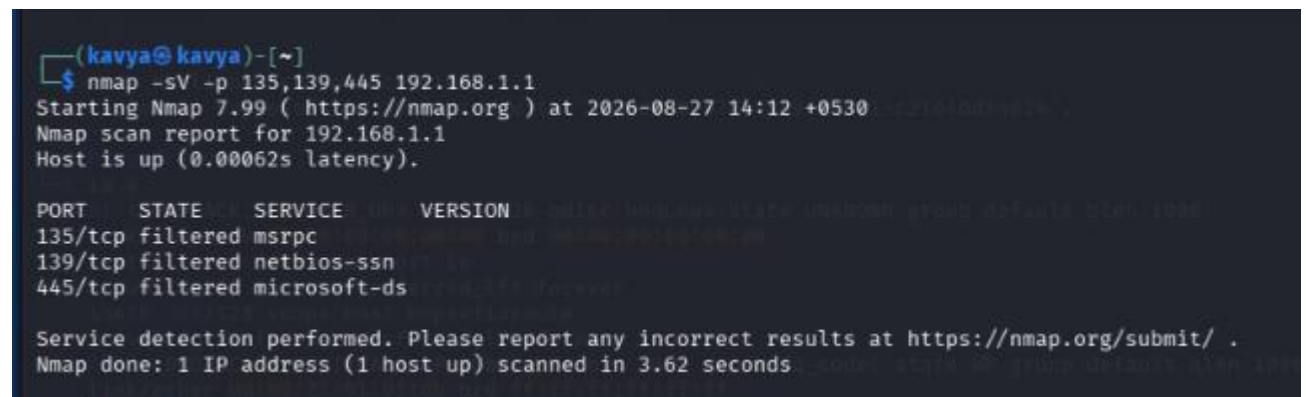
Q1. RPC Vulnerabilities in Legacy Windows Servers

Remote Procedure Call (RPC) allows Windows systems and applications to communicate with services running on other systems. In the given financial organization, delayed patching and exposed RPC services create a significant attack surface.

Attack Analysis

An attacker can first perform reconnaissance to identify systems and services exposed on the network. Nmap can be used to identify common RPC-related ports such as TCP 135 and dynamic RPC ports.

```
nmap -sV -p 135,139,445 <target-ip>
```



```
(kavya@kavya)-[~]
$ nmap -sV -p 135,139,445 192.168.1.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:12 +0530
Nmap scan report for 192.168.1.1
Host is up (0.00062s latency).

PORT      STATE      SERVICE
135/tcp    filtered  msrpc
139/tcp    filtered  netbios-ssn
445/tcp    filtered  microsoft-ds

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.62 seconds
```

The -sV option attempts to identify service versions. TCP port 135 is commonly associated with Microsoft RPC endpoint mapping, while ports 139 and 445 are associated with Windows networking services.

A broader service scan can be performed during authorized security testing:

`nmap -sV -O <target-ip>`

```
(kavya@kavya)-[~]
$ nmap -sV -O 192.168.1.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:12 +0530
Nmap scan report for 192.168.1.1
Host is up (0.0046s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      1.1
443/tcp   open  ssl/http  Connectra Check Point Web Security httpd
1 service unrecognized despite returning data. If you know the service/version, please submit the following
fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port80-TCP:V=7.99I=7%D=8/27%Time=6A8FF88E%P=x86_64-pc-linux-gnu%r(GetR
SF:equest,41,"HTTP/1.0\x20301\x20Moved\x20Permanently\r\nLocation:\x20htt
SF:ps://172\22\7\2\r\n\r\n")%r(HTTPOptions,41,"HTTP/1.0\x20301\x20Mov
SF:ed\x20Permanently\r\nLocation:\x20https://172\22\7\2\r\n\r\n");
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: VoIP adapter|bridge|general purpose
Running (JUST GUESSING): AT&T embedded (93%), Oracle Virtualbox (92%), Slirp (92%), QEMU (90%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: AT&T BGW210 voice gateway (93%), Oracle Virtualbox Slirp NAT bridge (92%), QEMU user
mode network gateway (90%)
No exact OS matches for host (test conditions non-ideal).
Service Info: Device: security-misc
```

The results can help the security team determine whether the server is running an outdated Windows version or exposed services that require attention.

On an authorized Windows server, administrators can check the RPC service using:

`Get-Service RpcSs`

```
PS C:\Users\kavya> Get-Service RpcSs

Status      Name                DisplayName
-----
Running     RpcSs               Remote Procedure Call (RPC)
```

They can also inspect Windows firewall rules:

`Get-NetFirewallProfile`

```
PS C:\Users\kavya> Get-NetFirewallProfile
```

```
Name : Domain
Enabled : True
DefaultInboundAction : NotConfigured
DefaultOutboundAction : NotConfigured
AllowInboundRules : NotConfigured
AllowLocalFirewallRules : NotConfigured
AllowLocalIPsecRules : NotConfigured
AllowUserApps : NotConfigured
AllowUserPorts : NotConfigured
AllowUnicastResponseToMulticast : NotConfigured
NotifyOnListen : True
EnableStealthModeForIPsec : NotConfigured
LogFileName : %systemroot%\system32\LogFiles\Firewall\pfirewall.log
LogMaxSizeKilobytes : 4096
LogAllowed : False
LogBlocked : False
LogIgnored : NotConfigured
DisabledInterfaceAliases : {NotConfigured}
```

and identify listening network connections:

Get-NetTCPConnection -State Listen

```
PS C:\Users\kavya> Get-NetTCPConnection -State Listen
```

LocalAddress	LocalPort	RemoteAddress	RemotePort	State	AppliedSetting
::	49682	::	0	Listen	
::1	49671	::	0	Listen	
::	49670	::	0	Listen	
::	49669	::	0	Listen	
::	49666	::	0	Listen	
::	49665	::	0	Listen	
::	49664	::	0	Listen	
::1	42050	::	0	Listen	
::1	24642	::	0	Listen	
::	8080	::	0	Listen	
::	445	::	0	Listen	
::	135	::	0	Listen	
0.0.0.0	55816	0.0.0.0	0	Listen	
0.0.0.0	49682	0.0.0.0	0	Listen	
0.0.0.0	49670	0.0.0.0	0	Listen	
0.0.0.0	49669	0.0.0.0	0	Listen	
0.0.0.0	49666	0.0.0.0	0	Listen	
0.0.0.0	49665	0.0.0.0	0	Listen	
0.0.0.0	49664	0.0.0.0	0	Listen	
127.0.0.1	44960	0.0.0.0	0	Listen	
127.0.0.1	44950	0.0.0.0	0	Listen	
0.0.0.0	8090	0.0.0.0	0	Listen	

If a vulnerable RPC service is successfully compromised, an attacker could potentially execute unauthorized operations, obtain an initial foothold, and attempt privilege escalation. Once higher privileges are obtained, the attacker could access confidential financial information, modify configurations, create unauthorized accounts, or move laterally through the network.

Risk Assessment

The risk is **high**, particularly because the organization is a financial institution. Delayed patching gives attackers more time to exploit publicly known vulnerabilities. Possible consequences include:

- Unauthorized access
- Remote code execution
- Privilege escalation
- Data theft
- Lateral movement

- Financial loss
- Service disruption
- Regulatory penalties
- Reputational damage

Recommended Approach

Critical RPC vulnerabilities should be patched as soon as possible. However, business continuity can be maintained through controlled maintenance procedures.

Recommended mitigation strategies are:

1. Apply security patches according to vulnerability severity.
2. Disable unnecessary RPC-related services.
3. Restrict RPC access using firewall rules.
4. Segment critical financial servers from ordinary user networks.
5. Allow RPC communication only between authorized systems.
6. Monitor unusual RPC traffic and connection attempts.
7. Maintain updated backups.
8. Test patches in a staging environment.
9. Maintain an inventory of legacy systems.
10. Establish emergency patching procedures for critical vulnerabilities.

Therefore, immediate remediation of critical RPC vulnerabilities is preferable, while controlled deployment, testing, backups, and network segmentation can reduce business disruption.

Q2. XSS, CSRF and Weak Session Management

The online transaction application suffers from XSS, CSRF, and weak session management. These vulnerabilities can become significantly more dangerous when combined.

Attack Analysis

First, an authorized security tester can inspect the application for XSS by identifying input fields that accept user-controlled data.

A simple harmless test string is:

```
<script>alert(1)</script>
```

If the application executes the script instead of safely displaying or encoding it, it indicates a potential XSS vulnerability.

For automated authorized testing, a vulnerability scanner such as OWASP ZAP can be used:

```
zapproxy
```

The application should also be tested for CSRF protection. Developers can inspect whether state-changing requests contain unpredictable anti-CSRF tokens.

For example, a request should contain a token similar to:

```
POST /transfer
```

```
CSRF-Token: <random-token>
```

```
(kavya@kavya)-[~]
$ curl -I http://google.com
HTTP/1.1 301 Moved Permanently
Location: http://www.google.com/
Content-Type: text/html; charset=UTF-8
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src 'nonce-gq3uDrYSLPamUYHiy-lTxA' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline' https: http;;report-uri https://csp.withgoogle.com/csp/gws/other-hp
Date: Thu, 27 Aug 2026 08:49:16 GMT
Expires: Sat, 26 Sep 2026 08:49:16 GMT
Cache-Control: public, max-age=2592000
Server: gws
Content-Length: 219
X-XSS-Protection: 0
X-Frame-Options: SAMEORIGIN

(kavya@kavya)-[~]
$ curl -I http://google.com/login
HTTP/1.1 404 Not Found
Transfer-Encoding: chunked
Date: Thu, 27 Aug 2026 08:49:56 GMT
Content-Type: text/html; charset=UTF-8
```

An attacker should not be able to perform a sensitive transaction simply by causing an authenticated user's browser to send a request.

Session cookies should also be examined. For example, a secure session cookie should contain appropriate security attributes:

Set-Cookie: session=<value>; Secure; HttpOnly; SameSite=Lax

The Secure attribute restricts transmission to HTTPS, HttpOnly reduces script access to the cookie, and SameSite helps reduce CSRF risk.

Combined Impact

An attacker could exploit an XSS vulnerability to execute unauthorized actions in the victim's browser. Weak session management can make account takeover easier if session identifiers are improperly protected. CSRF can further allow unwanted state-changing requests when the application does not verify the origin of the action.

This combination can result in:

- Account takeover
- Unauthorized transactions
- Session hijacking
- Personal-data exposure
- Financial loss
- Loss of customer trust

Risk Assessment

The risk is **high** because the application processes online transactions. Poor input validation allows malicious data to enter the application, while poor session management allows compromised sessions to remain usable.

Recommended Mitigation

1. Perform server-side input validation.
2. Use context-aware output encoding.
3. Implement Content Security Policy (CSP).

4. Use anti-CSRF tokens.
5. Use HTTPS/TLS throughout the application.
6. Set Secure, HttpOnly, and appropriate SameSite cookie attributes.
7. Regenerate session IDs after authentication.
8. Expire inactive sessions.
9. Invalidate sessions after logout.
10. Use strong random session identifiers.
11. Require additional authentication for high-value transactions.
12. Monitor suspicious transaction patterns.

Security testing tools such as OWASP ZAP can be used in an authorized testing environment to identify web vulnerabilities.

Thus, a layered security approach is required because fixing only one vulnerability does not eliminate the complete attack chain.

Q3. Outdated IIS Server and Remote Code Execution Risk

IIS is a Windows web-server platform used to host web applications. An outdated IIS server containing critical unpatched vulnerabilities presents a serious security risk, especially when the server is externally accessible.

Attack Analysis

An attacker can first identify the web server and determine its version:

`nmap -sV -p 80,443 <server-ip>`

```
(kavya@kavya)-[~]
$ nmap -sV -p 80,443 192.168.1.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:21 +0530
Stats: 0:00:39 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 14:23 (0:00:37 remaining)
Nmap scan report for 192.168.1.1
Host is up (0.0019s latency).

PORT      STATE SERVICE      VERSION
80/tcp    open  http         Microsoft IIS/10.0.9600.1713
443/tcp    open  ssl/https?   Microsoft IIS/10.0.9600.1713
1 service unrecognized despite returning data. If you know the service/version, please submit the following
fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port80-TCP:V=7.99%I=7%D=8/27%Time=6A8FFAA9%P=x86_64-pc-linux-gnu%r(GetR
SF:equest,41,"HTTP/1.0\x20301\x20Moved\x20Permanently\r\nLocation:\x20htt
SF:ps://172\.22\.7\.2/\r\n\r\n")%r(HTTPOptions,41,"HTTP/1.0\x20301\x20Mov
SF:ed\x20Permanently\r\nLocation:\x20https://172\.22\.7\.2/\r\n\r\n");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 51.08 seconds
```


A more detailed scan can be performed during authorized vulnerability assessment:

`nmap -sV -O <server-ip>`

```
(kavya@kavya)-[~]
$ nmap -sV -O 192.168.1.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:23 +0530
Nmap scan report for 192.168.1.1
Host is up (0.0040s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http
443/tcp   open  ssl/http Connectra Check Point Web Security httpd
1 service unrecognized despite returning data. If you know the service/version, please submit the following
fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port80-TCP:V=7.99%I=7%D=8/27%Time=6A8FFB26P=x86_64-pc-linux-gnu%r(GetR
SF:equest,41,"HTTP/1\0\x20301\x20Moved\x20Permanently\r\nLocation:\x20htt
SF:ps://172\22\7\2\2\r\n\r\n")%r(HTTPOptions,41,"HTTP/1\0\x20301\x20Mov
SF:ed\x20Permanently\r\nLocation:\x20https://172\22\7\2\2\r\n\r\n");
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: VoIP adapter|bridge|general purpose
Running (JUST GUESSING): AT&T embedded (93%), Oracle Virtualbox (92%), Slirp (92%), QEMU (90%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: AT&T BGW210 voice gateway (93%), Oracle Virtualbox Slirp NAT bridge (92%), QEMU user
mode network gateway (90%)
No exact OS matches for host (test conditions non-ideal).
Service Info: Device: security-misc

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.97 seconds
```

Security teams can use vulnerability scanners to determine whether the detected IIS version has known vulnerabilities.

For example, Nmap's vulnerability scripts may be used in an authorized environment

`nmap --script vuln -p 80,443 <server-ip>`

```
kavya@kavya: ~
Session Actions Edit View Help

(kavya@kavya)-[~]
$ nmap --script vuln -p 80,443 192.168.1.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:24 +0530
Nmap scan report for 192.168.1.1
Host is up (0.0022s latency).

PORT      STATE SERVICE
80/tcp    open  http
|_http-vuln-cve2014-3704: ERROR: Script execution failed (use -d to debug)
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
|_http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|   State: LIKELY VULNERABLE
|   IDs: CVE:2007-6750
|   Slowloris tries to keep many connections to the target web server open and hold
|   them open as long as possible. It accomplishes this by opening connections to
|   the target web server and sending a partial request. By doing so, it starves
|   the http server's resources causing Denial Of Service.
|
|   Disclosure date: 2009-09-17
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|   http://ha.ckers.org/slowloris/
|_http-internal-ip-disclosure:
|_ Internal IP Leaked: 172.22.7.2
443/tcp   open  https
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-vuln-cve2014-3704: ERROR: Script execution failed (use -d to debug)
|_ssl-ccs-injection: No reply from server (TIMEOUT)
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-aspnet-debug: ERROR: Script execution failed (use -d to debug)

Nmap done: 1 IP address (1 host up) scanned in 24.31 seconds
```


The purpose of this assessment is to identify potential weaknesses that require remediation rather than to damage the server.

On the Windows server, administrators can check IIS services using:

Get-Service W3SVC

They can also check the installed IIS version/configuration:

Get-WindowsFeature Web-Server

If an attacker successfully exploits a critical IIS vulnerability, the attacker may potentially execute unauthorized commands under the privileges of the affected service. This could result in malware installation, web-content modification, data theft, or movement into other internal systems.

Risk Assessment

The risk is **critical/high** because the server hosts both internal and external applications. Internet-facing systems are continuously exposed to automated scanning and attack attempts.

Delaying updates can result in:

- Remote code execution
- Unauthorized server access
- Data theft
- Website compromise
- Malware installation
- Lateral movement
- Service disruption

Immediate Patching vs Isolation

Immediate patching should be preferred for critical vulnerabilities. If patching cannot immediately be performed because of business requirements, temporary isolation should be used as a short-term measure.

Isolation can include:

- Restricting inbound traffic
- Allowing only required IP addresses
- Placing the server behind a firewall or WAF
- Removing unnecessary public exposure
- Increasing monitoring

Temporary isolation must not replace permanent patching.

Recommended Strategies

1. Test patches in a staging environment.
2. Maintain reliable backups.
3. Use redundant servers or load balancing.
4. Apply critical patches immediately.
5. Use a Web Application Firewall.
6. Disable unnecessary IIS modules.
7. Restrict network access.

8. Monitor IIS logs.
9. Perform regular vulnerability scans.
10. Establish emergency patching procedures.

Therefore, critical IIS vulnerabilities should be patched immediately whenever possible, with temporary isolation and redundancy used to maintain service availability.

Q4. Plaintext Mobile Storage and Unsecured Communication

The mobile application stores sensitive information in plaintext and communicates with backend servers through unsecured channels. These weaknesses can expose both user information and organizational systems.

Device-Based Attack

If a mobile device is lost, stolen, rooted, jailbroken, or compromised by malware, an attacker may be able to inspect application storage.

During authorized mobile application security testing, developers/security testers can inspect the application's stored data using appropriate platform debugging tools.

Sensitive data should never appear in readable form such as:

```
username=kavya  
password=123456  
phone=xxxxxxxxxxx
```

Instead, sensitive information should be protected using platform-provided secure storage.

For Android applications, developers should use the Android Keystore and encrypted storage mechanisms rather than plaintext files.

Network Attack

If the application communicates without HTTPS, network traffic may be exposed to interception or manipulation.

A security tester can check whether a server supports HTTPS:

```
curl -I https://example.com
```

The server's TLS configuration can also be assessed using an authorized TLS testing tool.

A basic connection check is:

```
openssl s_client -connect example.com:443
```

The objective is to verify that the application uses valid TLS certificates and secure encryption.

Impact

Plaintext storage can expose:

- Login credentials
- Personal information
- Authentication tokens
- Application data

Unsecured communication can expose information while it is travelling between the device and backend server.

Potential consequences include:

- Account takeover
- Identity theft
- Privacy violations
- Unauthorized transactions
- Financial loss
- Regulatory problems
- Reputational damage

Recommended Security Measures

1. Never store passwords in plaintext.
2. Use Android Keystore or iOS Keychain.
3. Encrypt sensitive local data.
4. Use HTTPS with modern TLS.
5. Validate server certificates.
6. Avoid transmitting unnecessary sensitive information.
7. Use secure authentication tokens.
8. Use short-lived sessions/tokens.
9. Protect cryptographic keys properly.
10. Perform regular mobile application security testing.

Therefore, encryption is required both for **data at rest** and **data in transit**. Secure storage and TLS-protected communication significantly reduce the possibility of credential theft and information disclosure.

Q5. Windows Firewall Disabled Accidentally

A Windows firewall controls incoming and outgoing network traffic. In the given scenario, the administrator disables the firewall for troubleshooting and forgets to enable it. This creates unnecessary exposure of network services.

Attack Analysis

An attacker can scan the exposed system to identify accessible services.

For an authorized assessment, Nmap can be used:

```
nmap -sV <target-ip>
```

A specific set of common Windows ports can also be checked:

```
nmap -p 135,139,445,3389 <target-ip>
```

These ports may correspond to services such as RPC, SMB, and Remote Desktop. The objective is to determine whether services that should not be externally reachable have become exposed.

On the Windows machine, the administrator can check firewall status:

```
Get-NetFirewallProfile
```

```
PS C:\Users\kavya> Get-NetFirewallProfile
```

```
Name                : Domain
Enabled              : True
DefaultInboundAction : NotConfigured
DefaultOutboundAction : NotConfigured
AllowInboundRules    : NotConfigured
AllowLocalFirewallRules : NotConfigured
AllowLocalIPsecRules : NotConfigured
AllowUserApps        : NotConfigured
AllowUserPorts       : NotConfigured
AllowUnicastResponseToMulticast : NotConfigured
NotifyOnListen       : True
EnableStealthModeForIPsec : NotConfigured
LogFileName           : %systemroot%\system32\LogFiles\Firewall\pfirewall.log
LogMaxSizeKilobytes   : 4096
LogAllowed            : False
LogBlocked            : False
LogIgnored            : NotConfigured
DisabledInterfaceAliases : {NotConfigured}
```

```
Name                : Private
Enabled              : True
DefaultInboundAction : NotConfigured
DefaultOutboundAction : NotConfigured
AllowInboundRules    : NotConfigured
AllowLocalFirewallRules : NotConfigured
AllowLocalIPsecRules : NotConfigured
```

The firewall can be enabled again using:

Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True

```
PS C:\Users\kavya> Get-NetFirewallProfile | Select-Object Name, Enabled
```

Name	Enabled
Domain	True
Private	True
Public	True

The administrator can verify the status afterward:

Get-NetFirewallProfile | Select-Object Name, Enabled

```
Windows PowerShell
PS C:\Users\kavya> Get-NetFirewallRule | Select-Object DisplayName, Enabled, Direction, Action

DisplayName
-----
Network Discovery (UPnP-Out)
Wi-Fi Direct Spooler Use (Out)
Remote Assistance (TCP-Out)
Network Discovery (SSDP-Out)
Network Discovery (WSD Events-Out)
Remote Event Log Management (NP-In)
Remote Scheduled Tasks Management (RPC)
Wi-Fi Direct Spooler Use (In)
Remote Assistance (TCP-Out)
Distributed Transaction Coordinator (TCP-Out)
Routing and Remote Access (L2TP-Out)
Core Networking - Packet Too Big (ICMPv6-Out)
Connected Devices Platform (UDP-Out)
Windows Collaboration Computer Name Registration Service (PNRP-In)
Network Discovery (NB-Name-Out)
Network Discovery (NB-Datagram-Out)
Windows Peer to Peer Collaboration Foundation (WSD-In)
Remote Event Log Management (RPC)
Core Networking - IPv6 (IPv6-In)
Connected Devices Platform - Wi-Fi Direct Transport (TCP-Out)
Network Discovery (LLMNR-UDP-In)
Remote Event Log Management (NP-In)
SNMP Trap Service (UDP In)
mDNS (UDP-Out)
Delivery Optimization (UDP-In)
Core Networking - Parameter Problem (ICMPv6-Out)
```

If the firewall is disabled, attackers may discover exposed services and attempt to exploit vulnerable applications, weak authentication, or misconfigured services.

Risk Assessment

The risk is **high** if critical services become reachable from untrusted networks.

Possible consequences include:

- Unauthorized network access
- Exploitation of vulnerable services
- Credential attacks
- Malware infection
- Data theft
- Lateral movement
- Compromise of critical systems

The incident also demonstrates the risk of relying entirely on manual security procedures.

Importance of Automated Policies

Security controls should not depend only on administrators remembering to restore them. Automated policies can detect configuration changes and restore the approved security baseline.

Organizations should use centralized management to enforce firewall settings and generate alerts when the firewall is disabled.

Recommended Administrative Safeguards

1. Avoid completely disabling the firewall.
2. Create temporary firewall rules instead.
3. Use least-privilege firewall rules.
4. Automatically restore firewall settings after troubleshooting.

5. Monitor firewall status continuously.
6. Generate alerts when the firewall is disabled.
7. Use centralized security-policy management.
8. Log administrative changes.
9. Restrict firewall-management privileges.
10. Conduct regular configuration audits.
11. Maintain a secure configuration baseline.
12. Train administrators in secure troubleshooting.

After detecting unauthorized connection attempts, the administrator should immediately restore the firewall and investigate the logs:

Get-WinEvent -LogName Security -MaxEvents 50

Network connections can also be reviewed:

Get-NetTCPConnection

```

PS C:\Users\kavya> Get-NetTCPConnection

LocalAddress      LocalPort RemoteAddress      RemotePort State      AppliedSetting
-----
:::                49682    :::                0           Listen
:::1              49671    :::                0           Listen
:::                49670    :::                0           Listen
:::                49669    :::                0           Listen
:::                49666    :::                0           Listen
:::                49665    :::                0           Listen
:::                49664    :::                0           Listen
:::1              42050    :::                0           Listen
:::1              24642    :::                0           Listen
:::                8080     :::                0           Listen
:::                445      :::                0           Listen
:::                135      :::                0           Listen
0.0.0.0           65222    0.0.0.0            0           Bound
0.0.0.0           64825    0.0.0.0            0           Bound
0.0.0.0           61668    0.0.0.0            0           Bound
0.0.0.0           60919    0.0.0.0            0           Bound
0.0.0.0           60918    0.0.0.0            0           Bound
0.0.0.0           59713    0.0.0.0            0           Bound
0.0.0.0           59149    0.0.0.0            0           Bound
0.0.0.0           57751    0.0.0.0            0           Bound
0.0.0.0           56664    0.0.0.0            0           Bound
0.0.0.0           56120    0.0.0.0            0           Bound
0.0.0.0           55868    0.0.0.0            0           Bound
0.0.0.0           55642    0.0.0.0            0           Bound
0.0.0.0           55305    0.0.0.0            0           Bound

PS C:\Users\kavya> Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True
PS C:\Users\kavya> Get-NetFirewallProfile | Select-Object Name, Enabled

Name      Enabled
----
Domain    True
Private   True
Public    True
  
```



```

(kavya@kavya)-[~]
$ nmap -sV 192.168.56.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:36 +0530
Stats: 0:00:13 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 33.33% done; ETC: 14:36 (0:00:12 remaining)
Nmap scan report for 192.168.56.1
Host is up (0.0022s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn      Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
903/tcp    open  ssl/vmware-auth  VMware Authentication Daemon 1.10 (Uses VNC, SOAP)
8080/tcp    open  http             Jetty 12.1.8
8090/tcp    open  tcpwrapped
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.99 seconds

(kavya@kavya)-[~]
$ nmap -p 135,139,445,3389 192.168.56.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 14:37 +0530
Nmap scan report for 192.168.56.1
Host is up (0.0017s latency).
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp    filtered ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned in 3.32 seconds

```

If compromise is suspected, the system should be isolated and investigated before returning it to normal operation.

Therefore, firewall mismanagement can significantly increase the attack surface of a Windows system. Automated policies, centralized management, monitoring, logging, and least-privilege administration are essential to prevent similar incidents while maintaining business continuity.